Treasury and the MultiAgency SDK

What the Treasury app needs from `@multiagency/sdk` and the platform, how each need is handled today, and what would improve the SDK from here.

Branch `harjaap-branch` · SDK 0.5.0 · platform `6ba0831` · November 2026

Summary

The Treasury app (owner UI in `web/`, app server in `apps/server/`, engines in `packages/core/`) runs on `@multiagency/sdk` 0.5.0. Upgrading from 0.4.1 needed no code changes beyond the version and the platform pin (PR #97).

The engines in `packages/core` don't use the SDK at all. They are pure decision logic: oracle, bands, sizing, anti-whipsaw, policy, levels, detectors, replay and mandate. The SDK matters where those decisions meet the platform: proposals, owner signatures, consents, reads and execution.

Three things decide where the app can go next:

1. **Owner UIs are moving to the app route.** The platform answered on platform#14: owner UIs move to `/apps/v1`, and the owner session gets no production host. Several procedures the owner UI uses have no app-route version yet (section 3.1).
2. **DAO-owned treasuries.** 0.5.0 adds DAO consents, votes and setups. The app server now supports DAO-owned agents (#20) against the SDK types, but DAO consent isn't deployed on any host yet, and the file calls have no idempotency key (section 3.4).
3. **Limits the signed policy can't express.** Venue exposure and the cash floor are enforced app-side only. They can refuse a trade the platform would allow, but nothing outside this app enforces them.

1. How the app uses the SDK

Part	Client	What it does through the SDK
Owner UI (`web/`)	`ownerClient` on the owner session (`/gw`)	Session and access, reads (overview, holdings, strategy, activity, inbox), owner actions prepared for the wallet to sign, plan execution streams
Proposals page (`web/src/proposals`)	none (calls the app server only)	Shows the owner's proposals; signs the exact `proposalText` in the wallet
App server (`apps/server/`)	`appClient` on `/apps/v1` with the deployment's `tap_` credential	Identity, consents, proposals (create, read, list, approve, reject, execute), the `watch` proposer, DAO consents and votes
Engines (`packages/core/`)	none	Pure logic; their decisions become platform proposals in A10.1 (#60)

2. SDK changes the app needed, and how each was resolved

#	Need	Resolution	Status
2.1	SDK 0.5.0 (DAO flows, fixes)	Upgraded in PR #97 with the platform pin moved to `6ba0831`. Typecheck and all tests pass.	Resolved
2.2	"token" means an asset in the SDK (`PROPOSAL_TOKENS`, `tokenAmount`), but the audit store refused any field named like `token` as a credential	The audit store now names credentials exactly (`sessionToken`, `accessToken`, `apiKey`, `mnemonic`, `seedPhrase`, ...), so `token`, `tokenIn` and `seed` record (#90)	Resolved in this app
2.3	Platform policy digest and owner signing for the mandate	The platform computes the mandate digest; the owner signs policy edits in the wallet (#59 closed as covered by the platform). A9.1 compiles answers to that policy plus app-side limits	Resolved by the platform
2.4	A bad NEP-413 signature reaches the SDK as a lost answer (the gateway's 400 isn't a typed refusal)	The app server verifies NEP-413 locally before relaying (`apps/server/src/http.ts`) and classifies refusals by status	Workaround in this app
2.5	A gateway 4xx comes back from the SDK as `unknown`; 429 isn't its own kind (platform#15)	`watch` treats `unknown` with HTTP 429 as a rate limit and backs off; other 4xx are treated as bugs and stop the agent	Workaround in this app
2.6	1,200 calls an hour per deployment, shared by every owner and `watch`	Identity answers cached 60 s; `watch` refuses to start past half the budget; owner requests rate-limited per account	Workaround in this app
2.7	Organization ids can't contain dots, but NEAR accounts do	The Organization is the owner's account with `.` written as `--` (`apps/server/src/consent.ts`)	Workaround in this app
2.8	`selfServiceTreasury` isn't in `gatewayDiscovery`	Read as a local extension of the discovery answer (`web/src/platform.ts`)	Workaround in this app
2.9	Gateway 401/403 denials need classifying before `ownerClient` sees them	Classified in `web/src/platform.ts`	Workaround in this app
2.10	Engine intents and platform proposals both called "proposal"	The engine's output is now an `Intent` (#63); a platform proposal stays a proposal	Resolved in this app

3. What the app still needs from the SDK or the platform

3.1 App-route versions of owner-session procedures

These procedures exist only on the owner session. If owner UIs move to `/apps/v1`, each needs an app-route equivalent or an explicit "not offered".

Procedure	Used by	Today
`setup` (identity, instance, overview fields)	owner UI frame	owner session only
`reconcileBooks`	portfolio	owner session only
`treasury/link`, `unlink`, `setConfidential`, `fund`	funding page	owner session only
`autopilot/tick` ("Run now")	automations (#7)	owner session only

Procedure	Used by	Today
`steward/propose`	steward page (#7)	owner session only
`inbox/list`, `inbox/dismiss`	attention inbox (#7)	owner session only
`/gw/agents`, `/gw/treasuries`	Treasury creation (#12)	not decided on the app route

3.2 Gaps no route covers yet

Gap	Why the app needs it	Issue
Approving a held withdrawal to a NEAR account (only rejecting is possible)	Payouts above a threshold wait for the owner	#62
An emergency freeze that confirms without a wallet signature or DAO vote	The red-hand stop: today a freeze waits for a signature or a vote before its intent expires, and a DAO stop revokes consents but doesn't freeze	#95, #62
Venue exposure and cash floor in the signed policy	Enforced app-side only; the platform would allow a trade they refuse	#49, #62
Treasury hosted setup on a real host, and Treasury in the stack's `--app` hosted areas	Self-service creation can't be exercised end to end	#12
A gateway reservation schema in the SDK	#12 would otherwise define the reservation locally	#12
A production `/apps/v1` host and a staging host	The app server has nowhere to run outside the local stack	#95
A rate limit per deployment, `Retry-After`, and 429 as its own kind	Back-off is guessed today	platform#15
The consent cap counts revoked consents	A user who reconnects often can be locked out	#20 threat model
Venue holdings and quoted slippage in reads	The policy needs venue exposure and slippage against the oracle median	A10.1 (#60)

3.3 New in 0.5.0 and now used

0.5.0 feature	Where the app uses it
`identity.signer`	The app server tells a DAO-owned agent from a wallet-owned one and routes each to its own flow (#20)
`accessOf`, `mayCall`	Members are gated by role against the DAO's on-chain policy, read and cached by the server
`app.daoConsents`	The server files the DAO's consent and follows it by state until the vote passes
`app.daoVotes`	Approve and reject become DAO votes, with the platform's `/confirm/dao/<hash>` link for voters
`app.daoSetups`, `owner/prepare` with `signer: "dao"`	Not used yet: DAO setup needs a host whose setup includes Treasury
`appClient(...).stream` for `sweep`, `rebalance`, `executePlan`	Not used: the owner UI streams these on the owner session (#7); they reach the app route only under a `treasury-execute` consent

3.4 Gaps found while building DAO agents

Gap	Effect today	Suggested SDK change
`daoConsents.file` and `daoVotes.file` take no request id	After a lost answer, the next click files a new request and the first is orphaned, using the 256-a-day budget (no duplicate DAO proposal results, since only the member's wallet creates it)	An idempotency key on `file`, as `proposals/create` has
No list of an app's DAO requests	The server must persist every request id itself, or a restart forgets open votes	`daoConsents.list` and `daoVotes.list` by organization, agent and proposal
`mayCall` has no entry for filing a consent or vote, or for revoking an app's consent	The app maps them to `canPropose` and the `autopilot/stop` rule by judgement	Named rules for these app-level actions
The skill text names `permits`, the example uses `mayCall`	Ambiguity about which to use	One name in docs and code
Reading a DAO request's state is also what relays it	The audit rule "record before the platform is asked" doesn't fit; the relay is recorded only as a result	A separate relay call, or a state read without side effects
DAO answers' HTTP statuses (404, 409, 410; 403, 409, 429 on file) are documented in prose only	The app maps them to gone, ended, expired by guesswork	Typed refusal kinds for DAO answers
`daoConsents.state` returns no `request` when `signed`; transaction actions are typed as loose `params`	The server answers from its own copy, and casts actions for the wallet	Complete, typed wire types
The voter check link is only inside `description`	The server rebuilds it from host and hash; the page refuses any other link	A typed `checkUrl` field
No DAO policy reader in the SDK	Each app calls the DAO's `get_policy` through its own RPC	A `daoPolicy(account)` read
DAO consent isn't on any host yet	Built and tested only against the SDK types and fakes	Deployment

3.5 Gaps found while building the owner UI

Gap	Effect today
`autopilot/tick` takes no input and returns no id	After a lost answer nothing links the attempt to a recorded run, so Run now is only held back for as long as the page is open, plus while a run or unresolved operation is visible
`autopilot/tick`, `steward/propose` and `inbox/*` exist only on the owner session; `rebalance` and `executePlan` reach the app route only under `treasury-execute`	Moving owner UIs to `/apps/v1` (platform#14) means reworking the automations, runs, steward and attention pages

4. Improvements to the SDK going forward

Ordered by how much they would remove from this app.

1. **Typed refusals everywhere.** Return every gateway 4xx as a refused result with a stable code (bad signature, expired, rate limited with `Retry-After`) instead of `unknown`. That removes this app's local NEP-413 check and its status-code guessing (2.4, 2.5).
2. **One owner surface.** Publish the app-route procedures in 3.1, or state which ones won't come, so owner UIs can move to `/apps/v1` without losing pages.
3. **Policy fields for app-side limits.** Venue exposure caps and a cash floor in the signed owner policy. The platform would then refuse what Ballast refuses, and the app-side checks become a second line instead of the only one.
4. **A budget-aware client.** Expose the deployment's remaining call budget, or a client-side limiter that shares it across processes, instead of each app estimating it.
5. **Reads the engines need.** Venue-level holdings, quoted slippage, rolling 24 h turnover and orders in the last hour as typed reads. These would feed the policy engine without app-side counters.
6. **Proposal legs from intents.** A helper that turns a sized intent (asset, side, USD size) into proposal legs in raw units with the token's decimals. This would make A10.1 a thin mapping.
7. **Emergency stop.** A freeze that takes effect at once and is confirmed afterwards, with its own audit event.
8. **Discovery flags in the schema.** Move `selfServiceTreasury` and similar flags into `gatewayDiscovery`'s typed answer.
9. **Organization ids that accept NEAR accounts.** Allow dots, or ship the mapping, so every app maps owners the same way.
10. **Idempotent, listable DAO requests.** A request id on `daoConsents.file` and `daoVotes.file`, a list by organization, agent and proposal, and a state read that doesn't relay (3.4).
11. **Run ids for `autopilot/tick`.** Accept a request id and return the run it started, so a lost answer can be followed instead of guessed (3.5).
12. **Test fixtures.** Publish the simulated stack's controls (fund, drop a response, sign as owner) as a supported package, with a documented way to let a developer's own wallet key own a local agent. Today that needs a local patch to the platform's test provider.

---

5. Issue status on this branch

Done means every acceptance criterion is met. **Built** means the code is complete but something outside this repo is still needed (data, an account, a host). **Blocked** means the platform has to act first. All 605 tests pass on the branch (239 core, 224 server, 142 web). The Arc UI overhaul of the owner UI is deferred.

The 31 open issues worked on this branch: every open issue except #60 and #61, which are assigned to ayushsingh82. Commits say `Closes #n` where the work is complete, so each issue closes when the branch merges to `main`. The engine work landed on `main` in #96, #98 and #99 while this branch was open; this branch merges it and keeps `main`'s reviewed fixes where both fixed the same review finding. This branch's own engine additions are the oracle's malformed-quote freeze (#29) and decision replay (#54).

Issue	Area	Status	What landed (commit)	Still open
#25 A3 epic	oracle	Done	with #29, #35	–
#29 A3.1 quote checks	oracle	Done	on main (#96); a malformed quote now freezes (2bb2376)	–
#35 A3.2 EMA, TWAP, warm-up	oracle	Done	on main (#96)	–

Issue	Area	Status	What landed (commit)	Still open
#26 A4 epic	bands	Done	with #36–#38	–
#36 A4.1 zones	bands	Done	main (#98, #99), including the missing-config fail-closed	–
#37 A4.2 sizing, guardrails	bands	Done	main (#98): one per-order cap shared with the policy	–
#38 A4.3 anti-whipsaw	bands	Done	main (#98): disarm every line crossed; partial state holds	–
#63 rename Proposal to Intent	bands	Done	main (#99)	–
#27 A5 epic	policy	Done	with #48–#50	–
#48 A5.1 limits	policy	Done	main (#98): shared cap	–
#49 A5.2 venue, cash floor	policy	Done	main (#98): zero spend refused	Platform can't sign these limits (SDK report 3.2)
#50 A5.3 levels, stale approval	policy	Done	main (#98): approval bound to its order and size; level checked	–
#43 A6 epic	detectors	Done	with #51, #52	–
#51 A6.1 market moves	detectors	Done	main (#98): stale history, bounded thresholds, missing config	–
#52 A6.2 data and system	detectors	Done	main (#99)	Live inputs arrive with A10.1 (#60)
#44 A7 epic	audit	Done	with #90, #54, #55	–
#90 chain.ts fixes	audit	Done	48e2a17	–
#54 A7.2 replay same decision	audit	Done	decision records and replay (2b65f0c)	Records are appended once the engines run in the server (#60)
#55 A7.3 head-hash anchor	audit	Built	hourly anchor on NEAR, read back and checked (d92974c)	Needs a NEAR account and a function-call key to run for real
#45 A8 epic	backtest	Done	with #56, #57	–
#56 A8.1 replay harness	backtest	Done	main (#99)	–
#57 A8.2 history, calibration	backtest	Built	main (#99)	12-month price data (H5)
#46 A9 epic	mandate	Done	with #58 (#59 closed as covered by the platform)	–
#58 A9.1 mandate compiler	mandate	Built	main (#99)	Questions, profiles and sleeve labels (H8, H6) are placeholders
#7 Owner UI portfolio	web	Built	rebalance, plan outcome, runs, Run now, attention, steward (24bb3b5)	No stack test yet; owner UIs move to `/apps/v1` later (platform#14)
#9 Guided walkthrough	web	Done	`/demo` (24bb3b5)	–

Issue	Area	Status	What landed (commit)	Still open
#12 Treasury creation	web	Built, blocked	creation, access wait, onboarding (05340d1)	No host or stack offers Treasury setup; `/gw/agents` has no SDK schema
#20 App server	server	Done	DAO-owned agents and missing tests (dfd70da)	DAO consent isn't on any host yet
#47 A10 umbrella	SDK flows	Out of scope	–	Only #60 and #61 remain (ayushsingh82)
#62 A23 SDK re-scope	SDK	Done	the gap table is section 3 of the SDK report	Needs posting on the issue
#95 Staging, red-hand stop	ops	Blocked	–	A staging `/apps/v1` host, a `tap_` credential, and an emergency freeze from the platform

Appendix: running the app locally

The owner UI only works when it is served by the platform's stack.

1. Check out the platform beside the repo at the pinned commit, then run `pnpm install` in both.
2. Build the owner UI: `pnpm --filter @treasury/web build`.
3. Start the stack with `--treasury --frontend ../treasury/web/dist`.

The stack's simulated chain trusts only its built-in test key. To sign in with a real wallet locally, start the stack with that wallet's account as `--owner`. You also need the local `STACK_OWNER_PUBLIC_KEY` change to the platform's test provider (item 12 above).